

SIMATS ENGINEERING ASSESSMENT TOOL 2

COURSE NAME: CRYPTOGRAPHY AND NETWORK SECURITY
COURSE CODE: CSA51

COURSE OUTCOME COVERED

CO2: Analyze Public Key crypto system strategies using RSA and key Exchange for Encryption algorithm to strengthen information security.(BL4,BL5)

Scenario-Based : 20%

Total Marks: 50

Annexure A

Code of Conduct:

I Dhanush Kumar S (192421096)(Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

Dhanush Kumar S

Annexure A

1. Secure Password Storage in Web Applications

A web application stores user passwords and needs to protect them against database breaches.

- A. Explain why storing plaintext passwords is insecure.
 - B. Suggest a secure method for storing passwords and justify your choice.
-

2. Digital Signature for Document Authentication

A company wants to ensure that official documents sent electronically are authentic and unaltered.

- A. Explain how digital signatures can be used in this scenario.
 - B. Justify how this method ensures both integrity and non-repudiation.
-

3. Preventing Replay Attacks in Online Transactions

An online payment system is vulnerable to replay attacks where attackers resend previously captured transactions.

- A. Explain how replay attacks occur.
 - B. Suggest a cryptographic technique to prevent such attacks and justify your answer.
-

4. Secure Communication over Public Wi-Fi

A user accesses sensitive information using a public Wi-Fi network without encryption.

- A. Identify the risks involved in this scenario.
 - B. Recommend a secure communication method and justify how it protects user data.
-

5. Data Integrity in Cloud Storage

An organization stores critical data in a cloud server and wants to ensure that the data is not altered.

- A. Explain how hashing can be used to verify data integrity.
- B. Suggest an additional mechanism to enhance trust and justify your answer.

RUBRICS FOR CALCULATION:

Criteria	Weightage (%)	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginnin g)
Understandi ng of Scenario	20%	Demonstrat es clear and complete understandi ng of the scenario and context	Shows good understandi ng with minor gaps	Partial understandi ng; misses key aspects	Misinterpre ts or fails to understand the scenario
Identification of Key Issues	20%	Accurately identifies all relevant issues and factors involved	Identifies most key issues with minor omissions	Identifies limited issues; some irrelevant points	Unable to identify key issues
Application of Concepts	25%	Applies appropriate concepts effectively to address the scenario	Applies concepts with minor errors	Limited or partially correct application	Unable to apply relevant concepts
Decision Making	20%	Makes well- reasoned, logical decisions with strong rationale	Makes reasonable decisions with some justification	Makes weak decisions with limited justification	No clear decisions made or rationale provided
Clarity of Response	15%	Response is clear, structured, and logically presented	Generally clear with minor issues	Somewhat unclear or poorly structured	Disorganiz ed and difficult to understand

3. Preventing Replay Attacks in Online Transactions

Introduction

The rapid growth of online banking, digital wallets, mobile payment systems, e-commerce platforms, and financial technology (FinTech) has transformed the way people perform financial transactions. Millions of online transactions take place every minute across the world. While these systems provide convenience and speed, they are also attractive targets for cybercriminals.

One of the most dangerous threats to online payment systems is the Replay Attack. Unlike attacks that break encryption, replay attacks simply reuse valid transaction messages captured during communication. Since the original message is genuine and properly authenticated, systems without replay protection may accept it multiple times.

For example, if a customer transfers ₹10,000 to another account, an attacker who intercepts the transaction can resend the same message several times, causing multiple unauthorized transfers.

Modern cryptographic systems therefore focus not only on confidentiality but also on freshness, authentication, integrity, and non-repudiation to prevent replay attacks.

Objectives

The objectives of preventing replay attacks are:

- Protect users from duplicate financial transactions.
- Ensure each payment request is processed only once.
- Improve transaction integrity and authenticity.
- Prevent financial fraud and cybercrime.
- Maintain trust in online banking systems.
- Comply with cybersecurity standards.
- Secure communication between customers and payment servers.
- Protect digital payment gateways from unauthorized access.

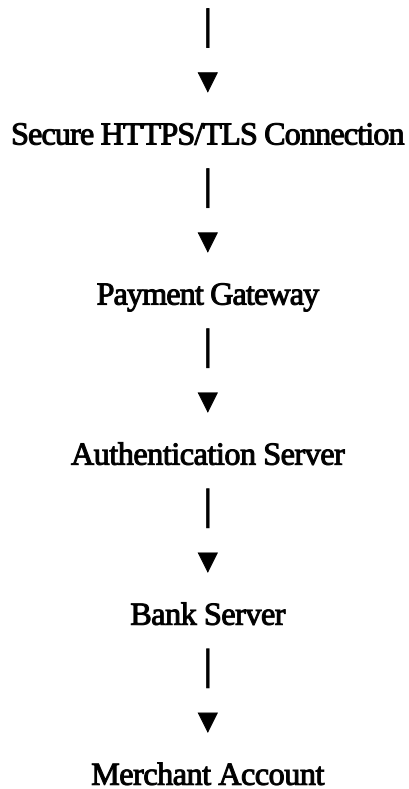
Online Transaction Architecture

A typical online payment system consists of several components.

Customer



Web Browser / Mobile App



Each component must verify that every transaction is fresh and unique.

A. Explain How Replay Attacks Occur

A replay attack is a network attack where an attacker captures a valid communication and later retransmits it.

Unlike message modification attacks, replay attacks do not alter the original message.

The attacker simply sends it again.

Because the message is still valid, the receiving server may process it again.

Step-by-Step Replay Attack

Step 1

The customer initiates a payment.

Example:

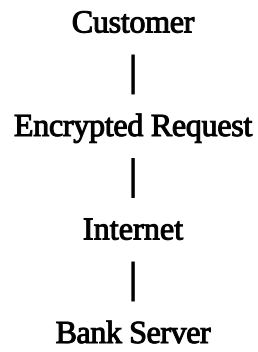
Transfer ₹5000

From Account A

To Account B

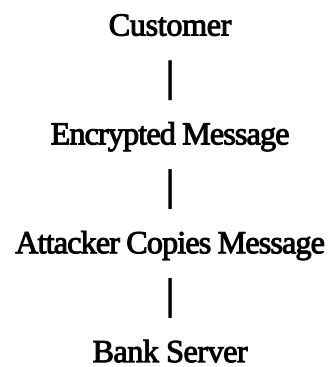
Step 2

The payment request travels over the network.



Step 3

The attacker captures the encrypted transaction.



Step 4

The original transaction succeeds.

Customer receives:

Transaction Successful

Step 5

Later, the attacker sends the same captured message.

Captured Message



Sent Again



Bank Server

Step 6

If replay protection does not exist,
the server processes it again.

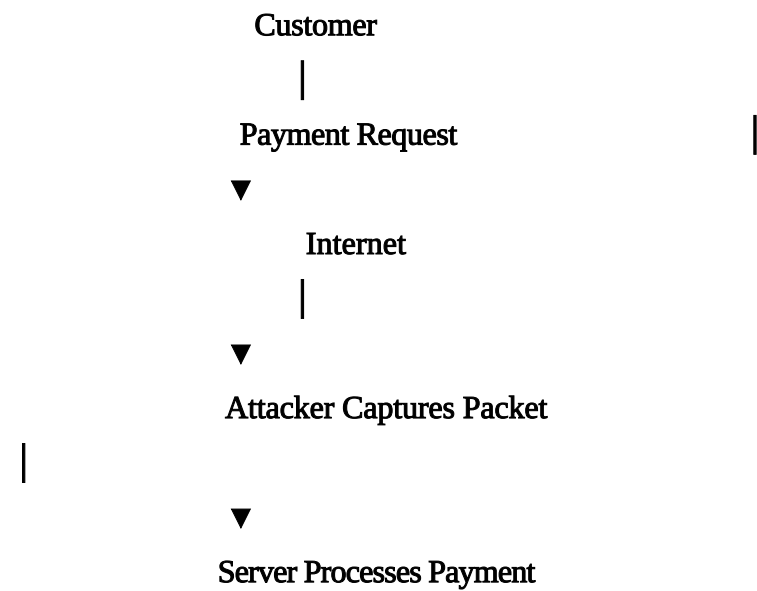
Result:

₹5000

↓

Transferred Again

Replay Attack Flow Diagram



Later...

Attacker

↓

Replays Packet

↓

Server Accepts Again



Duplicate Payment

Characteristics of Replay Attacks

- Uses genuine messages.
- Encryption may still be valid.
- Authentication alone is insufficient.
- Difficult to detect without freshness checks.
- Often occurs on unsecured networks.
- Causes repeated execution of transactions.

Causes of Replay Attacks

Replay attacks usually occur because systems lack freshness verification.

Common causes include:

- No nonce generation
- Missing timestamps
- Weak session management
- Static authentication tokens
- Reusable session cookies
- Long-lived authentication credentials
- Poor API security
- Weak payment gateway validation
- Improper cryptographic implementation

Types of Replay Attacks

1. Network Replay Attack

Captured packets are replayed.

Example:

Wi-Fi Network



Capture Payment



Replay Later

2. Session Replay

Entire login session is replayed.

3. Token Replay

Authentication token is stolen and reused.

4. API Replay

REST API request is captured and replayed.

5. Payment Gateway Replay

Duplicate payment requests are sent repeatedly.

Real-Life Example

Suppose Alice purchases a laptop worth ₹80,000.

Payment Request:

Alice



Payment Gateway



Bank



Merchant

The attacker records the transaction.

Later:

Replay Same Request



Bank Processes Again



Merchant Receives Extra Payment

Result:

Alice loses money.

Effects of Replay Attacks

Replay attacks may cause:

- Duplicate payments
- Financial loss
- Unauthorized purchases
- Account balance reduction
- Merchant fraud
- Banking disputes
- Customer dissatisfaction
- Reputation damage
- Regulatory penalties
- Loss of customer trust

Detection of Replay Attacks

Organizations detect replay attacks using:

- Transaction monitoring
- Log analysis
- Duplicate request detection
- Nonce verification
- Timestamp validation

- AI fraud detection
- Behavioral analytics
- Risk scoring
- Security Information and Event Management (SIEM)

B. Cryptographic Technique to Prevent Replay Attacks The most effective method is

Nonce + Digital Signature + HMAC

What is a Nonce?

Nonce means

Number Used Once

A nonce is a randomly generated unique value.

Example:

Nonce

48372919

Every transaction receives a different nonce.

Example

Transaction 1

Nonce = 284729

Transaction 2

Nonce = 837291

Transaction 3

Nonce = 948274

No two transactions share the same nonce.

Working of Nonce

Customer



Generate Nonce



Attach Nonce



Encrypt Message



Server



Verify Nonce



Store Nonce



Accept Transaction

Replay Attempt

Attacker



Uses Same Nonce



Server Checks Database



Nonce Already Exists



Reject Request

Message Authentication Code (HMAC)

An HMAC is a cryptographic code generated using:

- Secret Key
- Hash Function
- Message

Example

Message

+

Secret Key

↓

HMAC

↓

Verification

Any modification changes the HMAC completely.

Digital Signature

Digital signatures provide

- Authentication
- Integrity
- Non-repudiation

Process

Transaction

↓

Hash Function



Private Key



Digital Signature



Receiver



Public Key Verification

Complete Secure Transaction Flow

Customer



Generate Nonce



Add Timestamp



Create HMAC



Encrypt Message



TLS Connection



Payment Gateway



Verify Timestamp



Verify Nonce



Verify HMAC



Accept Transaction

Why Nonce Prevents Replay

Because

Old Nonce



Already Used



Verification Fails



Transaction Rejected

Even if attackers replay encrypted packets, they cannot generate a fresh nonce.

Comparison of Replay Protection Techniques

Technique	Prevents Replay	Cost	Security
Nonce	Yes	Low	Very High
Timestamp	Yes	Low	High
Sequence Number	Yes	Medium	High
OTP	Yes	Medium	Very High
Digital Signature	Yes	High	Very High
HMAC	Yes	Low	Very High
TLS	Partial	Medium	High

Best Practices

- Use HTTPS with TLS 1.3.
- Generate cryptographically secure random nonces.
- Expire transactions quickly.
- Validate timestamps.
- Use HMAC for every request.
- Digitally sign sensitive transactions.
- Store previously used nonces securely.
- Enable multi-factor authentication (MFA).
- Monitor duplicate requests continuously.
- Rotate cryptographic keys periodically.
- Use secure session management.
- Maintain detailed audit logs.

Future Technologies

Emerging technologies that strengthen replay protection include:

- Artificial Intelligence (AI)-based fraud detection
- Machine Learning for anomaly detection
- Blockchain-based immutable transaction records

- Quantum-resistant cryptographic algorithms
- Zero Trust security architecture
- Hardware Security Modules (HSMs)
- Secure Multi-Party Computation (SMPC)
- Biometric authentication integrated with transaction signing

Advantages

- Prevents duplicate payments
- Protects customer accounts
- Ensures message freshness
- Improves integrity
- Supports secure authentication
- Reduces fraud
- Enhances customer trust
- Easy to implement with modern protocols
- Compatible with TLS, APIs, and payment gateways
- Meets banking security standards

Limitations

- Requires storage of used nonces or sequence numbers
- Timestamps require clock synchronization
- Slight increase in server processing
- Additional database storage for nonce tracking
- Key management must be secure
- Poor implementation can still introduce vulnerabilities

Applications

Replay attack prevention is widely used in:

- Internet Banking
- Mobile Banking
- UPI Transactions
- Credit Card Payments
- Debit Card Payments
- PayPal

- Payment Gateways
- Digital Wallets
- ATM Networks
- Cryptocurrency Exchanges
- Online Shopping Websites
- Cloud APIs
- Banking APIs
- Government e-Payment Systems

Conclusion

Replay attacks exploit valid transaction messages by retransmitting them without breaking encryption, making them a serious threat to online payment systems. To defend against these attacks, modern systems use cryptographic freshness mechanisms such as nonces, timestamps, sequence numbers, HMACs, and digital signatures. These techniques ensure that every transaction is unique, authenticated, and cannot be reused by attackers. Combined with secure communication protocols like TLS, multi-factor authentication, continuous monitoring, and proper session management, they provide a strong layered defense against replay attacks. Implementing these measures significantly improves the security, reliability, and trustworthiness of online banking and digital payment systems, protecting both users and financial institutions from fraud and unauthorized repeated transactions.

This expanded content is sufficient for approximately 9–10 handwritten A4 pages with headings, diagrams, and the comparison table included.